

Security+ 1.2 · The CIA Triad

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 1.2 — The CIA Triad (5:17)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: 3 objectives: CONFIDENTIALITY (only those who should, see — encryption, ACL, MFA, classification); INTEGRITY (data is not improperly altered — hash, digital signature, certificate); AVAILABILITY (service up — redundancy, failover, patch, backup). Every control serves at least 1 of the 3.

High-Yield Core Concepts Tested on Exam

- C breached: leak/eavesdropping. I breached: altered/fraudulent. A breached: service down.
- Hash provides I, NOT C (does not encrypt content)
- Digital signature provides I + authentication + non-repudiation (the 3-in-1)
- AES = confidentiality; RSA = key exchange + signature
- 'which of the three goals was COMPROMISED' = the classic question

Exam Tips & Classic Scenarios

- Scenario 'someone saw the data'=C · 'someone altered'=I · 'I cannot access'=A
- Caution: 'email sent by unauthorized character' can be I (sender integrity) or C if the content leaked

Typical Exam Scenario: Typical scenario: 'email with attachment that replaces the payment order' = Integrity; 'unauthorized access to patient data' = Confidentiality; 'site down on Black Friday' = Availability.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 1.2 — The CIA Triad)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **IPSEC:** Internet Protocol Security: Network layer (L3) security suite consisting of Authentication Header (AH for integrity), Encapsulating Security Payload (ESP for encryption), and IKE for key exchange.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. An attacker intercepts and READS a confidential communication between two systems without authorization. Which objective of the CIA triad was directly compromised?

- A)** Integrity
- B)** Confidentiality
- C)** Availability
- D)** Non-repudiation

2. An attacker INJECTS code into a message sent to a bank, causing the bank to execute a transfer that the original user did not order. Which objective of the triad was compromised?

- A) Confidentiality**
- B) Integrity**
- C) Availability**
- D) Authentication**

3. An e-commerce web server becomes completely inaccessible due to a distributed denial-of-service (DDoS) attack. Which objective of the CIA triad was compromised?

- A) Confidentiality**
- B) Integrity**
- C) Availability**
- D) Authenticity**

4. What does a cryptographic HASH function (such as SHA-256) provide and what does it NOT provide?

- A) Provides integrity; does NOT provide confidentiality (does not encrypt)**
- B) Provides confidentiality; does NOT provide integrity**
- C) Provides availability; does NOT provide integrity**
- D) Provides all three at the same time**

5. Which cryptographic control simultaneously provides: data integrity + author authentication + non-repudiation?

- A) Pure SHA-256 hash**
- B) Symmetric AES encryption**
- C) Digital signature with private key**
- D) Offline tape backup**

6. Confidential data is being transmitted between a remote user and the corporate server over the internet. Which data state and corresponding protection?

- A)** At rest — BitLocker disk encryption
- B)** In transit — TLS tunnel / IPsec VPN
- C)** In use — secure CPU enclaves
- D)** Rest / transit / use — all indistinct

7. A financial company must guarantee before a judicial audit that a manager cannot deny having authorized a bank transfer. Which technical guarantee is required?

- A)** AES encryption
- B)** Non-repudiation via digital signature
- C)** High-availability cluster
- D)** MD5 hash of the message

8. A web application stores passwords in a database using salted hashing (e.g., bcrypt). Which primary objective of the triad does this protect and why?

- A)** Availability — speeds up backup
- B)** Integrity — ensures the file does not corrupt
- C)** Confidentiality — even if the database is leaked, attackers cannot read plaintext passwords
- D)** Authentication — proves the user's identity

9. SCENARIO: During a nightly maintenance routine, a batch script with a logic error improperly alters the credit limit fields of 10,000 customers, without malice or external attack. Which pillar of the CIA triad was directly violated?

- A)** Confidentiality
- B)** Integrity
- C)** Availability
- D)** Non-repudiation

10. SCENARIO: A hospital implements electronic health record servers with redundant power supplies, a diesel generator, synchronous multi-site replication, and automatic load balancing. This architecture was designed to prioritize:

- A)** Confidentiality
- B)** Integrity
- C)** Availability
- D)** Non-repudiation

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — Confidentiality.

Confidentiality ('only those who are authorized can see'): unauthorized reading by a third party breaches the secrecy of the information.

✗ Why the others are wrong:

- *Integrity*: Integrity ensures data is not altered or tampered with. Reading does not modify data.
- *Availability*: Availability ensures systems and data are accessible when needed. Reading does not disrupt availability.
- *Non-repudiation*: Non-repudiation ensures that a party cannot deny performing an action. It is not directly compromised by unauthorized reading.

2) B — Integrity.

Integrity: the data was tampered with in transit, ceasing to be accurate and reliable.

3) C — Availability.

Availability: the service went down and legitimate customers cannot access the system.

4) A — Provides integrity; does NOT provide confidentiality (does not encrypt).

✓ **Why it is correct:** A cryptographic hash function is one-way: it generates a unique fingerprint to verify whether data has changed (integrity), but it does not hide or encrypt the content, so it does not provide confidentiality.

✗ Why the others are wrong:

- *Provides confidentiality; does NOT provide integrity*: Incorrect. Hash functions do not encrypt data, so they do not provide confidentiality. They are specifically designed to ensure integrity.
- *Provides availability; does NOT provide integrity*: Incorrect. Hash functions do not directly ensure availability; they are used for integrity verification.
- *Provides all three at the same time*: Incorrect. Hash functions provide integrity only, not confidentiality or availability.

5) C — Digital signature with private key.

A digital signature encrypts the hash with the sender's private key, ensuring integrity + authenticity + non-repudiation.

✗ Why the others are wrong:

- *Pure SHA-256 hash*: Provides integrity but not authentication or non-repudiation, as anyone can generate a hash.
- *Symmetric AES encryption*: Provides confidentiality but not non-repudiation, as the shared key could be used by either party.
- *Offline tape backup*: Provides availability and recovery but not integrity, authentication, or non-repudiation.

6) B — In transit — TLS tunnel / IPsec VPN.

Data in transit travels over the network and must be protected with TLS or VPN.

7) B — Non-repudiation via digital signature.

Non-repudiation: prevents the author from denying authorship of the transaction, because only their exclusive private key could have generated the signature. Digital signatures provide proof of origin and integrity, ensuring the signer cannot later deny the action.

✗ Why the others are wrong:

- *AES encryption*: Provides confidentiality, not non-repudiation. Encryption alone does not prove who sent the message.
- *High-availability cluster*: Ensures availability and uptime, not non-repudiation.
- *MD5 hash of the message*: Provides integrity but not non-repudiation; MD5 is also cryptographically broken and vulnerable to collisions.

8) C — Confidentiality — even if the database is leaked, attackers cannot read plaintext passwords.

✓ **Why it is correct:** Confidentiality: salted hashing ensures that the secret (the password) is not revealed even if the table is stolen. Hashing is a one-way function, and the salt prevents rainbow table attacks and ensures identical passwords produce different hashes.

✗ **Why the others are wrong:**

- *Availability — speeds up backup*: Hashing does not directly impact availability or backup speed. Availability ensures data and systems are accessible when needed, which is unrelated to password storage.
- *Integrity — ensures the file does not corrupt*: While hashing can be used for integrity checks, the primary purpose here is to protect the confidentiality of passwords, not to detect corruption. Integrity ensures data is not altered, but the scenario focuses on preventing unauthorized reading.
- *Authentication — proves the user's identity*: Authentication is the process of verifying identity, but the use of salted hashing is a mechanism to protect stored credentials, not the authentication process itself. The question asks which objective of the triad is protected, and confidentiality is the correct answer.

9) B — Integrity.

Integrity: the incorrect modification of accounting data corrupted the accuracy and integrity of the database, regardless of whether there was malice.

10) C — Availability.

✓ **Why it is correct:** Availability: UPS systems, generators, replication, and redundancy exist to ensure that doctors can access medical records 24/7 without interruptions. The scenario focuses on ensuring continuous access to critical systems, which is the core of the Availability pillar of the CIA triad.

✗ **Why the others are wrong:**

- *Confidentiality*: Confidentiality ensures data is accessible only to authorized individuals. The described measures (redundant power, replication, load balancing) do not directly address access control or encryption; they ensure uptime, not secrecy.
- *Integrity*: Integrity ensures data is not altered improperly. While replication can help maintain consistency, the primary goal of the described architecture is to keep systems running, not to detect or prevent unauthorized modifications.
- *Non-repudiation*: Non-repudiation ensures that a party cannot deny having performed an action. The scenario does not mention logging, digital signatures, or audit trails; it focuses on system resilience and uptime.

